

Clase 331 — IA generativa y LLMs en ciberseguridad: panorama, capacidades y límites

Parte: **18 — IA aplicada a la ciberseguridad** · Fuente: *NIST AI RMF 1.0 (AI 100-1)* y *OWASP Top 10 for LLM Applications* 🕒 Duración estimada: **90 min** · Nivel: **Intermedio**

Objetivo

Entender qué son los modelos generativos de lenguaje (LLM) y qué papel real juegan como **herramienta de trabajo** para hacer ciberseguridad: dónde aportan valor (acelerar tareas repetitivas, sintetizar información, redactar) y dónde fallan (alucinaciones, falta de contexto, datos desactualizados). Al terminar sabrás decidir cuándo apoyarte en un LLM y cuándo NO confiar en su salida sin verificación humana.

Importante: esta parte trata de **usar IA para HACER seguridad** (ofensiva y defensiva). No la confundas con la Parte 15, que trata de **proteger a la propia IA** (seguridad DE los modelos: prompt injection, envenenamiento de datos, etc.). Aquí el LLM es tu instrumento; allá es tu activo a defender.

Resultados de aprendizaje

Al finalizar, el alumno podrá:

1. **Explicar** en términos operativos cómo un LLM genera texto y por qué eso condiciona su fiabilidad.
2. **Clasificar** tareas de ciberseguridad según si un LLM aporta valor alto, medio o nulo.
3. **Detectar** alucinaciones y afirmaciones no verificables en la salida de un modelo.
4. **Diseñar** un flujo de trabajo con verificación humana obligatoria (human-in-the-loop).
5. **Aplicar** el marco NIST AI RMF (Govern, Map, Measure, Manage) a un caso de uso propio.

Temas

#	Tema	Por qué importa
1	Qué es un LLM (predicción de tokens)	Explica por qué "suena seguro" aunque se equivoque
2	Capacidades reales en seguridad	Evita expectativas mágicas y decepciones
3	Alucinaciones y confabulación	La causa nº1 de errores graves en producción
4	Corte de conocimiento y falta de contexto	Un CVE de esta semana puede no existir para el modelo
5	Verificación humana (human-in-the-loop)	Frontera entre asistente útil y riesgo operativo
6	Prompting efectivo para tareas técnicas	Mejora señal/ruido de la respuesta
7	Gobernanza: NIST AI RMF y política de uso	Marco para adoptar IA con responsabilidad

Definiciones y características

- **LLM (Large Language Model):** modelo estadístico que predice el siguiente *token* (fragmento de texto) dado el contexto previo. **Característica clave:** no "sabe" hechos; reproduce patrones plausibles del texto con el que fue entrenado.
- **Alucinación (o confabulación):** salida gramaticalmente correcta y confiada, pero factualmente falsa o inventada (una CVE inexistente, una flag de `nmap` que no existe). **Característica clave:** es indistinguible del acierto sin verificación externa.
- **Corte de conocimiento (knowledge cutoff):** fecha hasta la que el modelo tiene datos de entrenamiento. **Característica clave:** todo lo posterior le es desconocido salvo que se le aporte por contexto.
- **Ventana de contexto:** cantidad de texto que el modelo puede "ver" a la vez. **Característica clave:** fuera de ella, el modelo no recuerda; hay que reinyectar la información relevante.
- **Human-in-the-loop (HITL):** patrón donde una persona revisa y autoriza antes de que la salida del modelo tenga efecto real. **Característica clave:** convierte una sugerencia en una acción responsable y trazable.
- **Grounding / RAG:** técnica de anclar la respuesta a documentos verificados aportados al modelo. **Característica clave:** reduce alucinaciones al forzar que responda desde fuentes concretas.
- **Temperatura:** parámetro que controla la aleatoriedad de la salida. **Característica clave:** temperatura baja da respuestas más deterministas, útil para tareas técnicas precisas.

Herramientas y preparación

- Un cliente de LLM: interfaz web (Claude, ChatGPT, Gemini) o CLI (**Claude Code**, **Gemini CLI**) — estos últimos son la base de las clases siguientes.
- Cuaderno de laboratorio (Markdown) para registrar prompts, respuestas y verificaciones.
- Acceso a fuentes autoritativas para contrastar: [MITRE ATT&CK](#), [NVD](#), [OWASP](#), páginas `man` de las herramientas.
- **Recordatorio:** nunca pegues datos sensibles (credenciales, PII, código propietario, hallazgos de un cliente) en un LLM de terceros sin autorización y sin conocer su política de retención de datos.

Laboratorio guiado

Objetivo: medir empíricamente dónde ayuda y dónde falla un LLM. **Todo el ejercicio es documental;** no se ataca ningún sistema.

1. **Prepara la bitácora.** Crea `bitacora-llm.md` con columnas: *Tarea* | *Prompt* | *Respuesta resumida* | *¿Verificado?* | *Veredicto*.
2. **Tarea de síntesis (valor alto).** Pide al modelo: "Explica la diferencia entre un escaneo SYN y un escaneo connect de nmap". Verifica contra la documentación oficial de nmap. Registra si acierta.
3. **Tarea de generación de comando (valor medio).** Pide: "Dame el comando nmap para un escaneo de los 1000 puertos más comunes con detección de versión". Antes de ejecutar nada, **valida cada flag** con `man nmap`. Anota flags inexistentes o mal usadas.
4. **Prueba de alucinación (fallo esperado).** Pregunta por una CVE muy reciente o inventada: "Resume la CVE-2029-99999". Observa si el modelo confabula detalles. Registra el comportamiento.
5. **Corte de conocimiento.** Pregunta "¿Cuál es la última versión de Metasploit?" y contrasta con la web oficial. Anota el desfase.

- 6. **Grounding.** Copia un fragmento real de un aviso de seguridad y pide que lo resuma **solo con esa información**. Compara la calidad frente al paso 4.
- 7. **Cierre.** Cuenta cuántas respuestas requirieron corrección humana. Escribe una conclusión de una frase sobre la fiabilidad sin verificación.

 Ejercicios

- 1. Redacta una definición propia de "alucinación" con un ejemplo del dominio de redes.
- 2. Clasifica 10 tareas de tu trabajo (o del curso) en valor alto/medio/nulo para un LLM y justifica.
- 3. Escribe tres versiones de un mismo prompt (vago, específico, con contexto) y compara las respuestas.
- 4. Diseña una checklist de verificación de 5 puntos para cualquier comando sugerido por IA.
- 5. Investiga y resume la política de retención de datos de un proveedor de LLM que uses.
- 6. Mapea un caso de uso propio a las cuatro funciones del NIST AI RMF (Govern, Map, Measure, Manage).

 Reto verificable

Elabora una **"Política de uso responsable de LLM"** de una página para un equipo de seguridad ficticio.

Criterio de aceptación: el documento debe (a) listar al menos 3 usos permitidos y 3 prohibidos, (b) exigir verificación humana antes de ejecutar cualquier acción con efecto, (c) prohibir el envío de datos sensibles a modelos externos sin autorización, y (d) referenciar explícitamente el NIST AI RMF. Un compañero debe poder leerlo y saber qué puede y qué no puede hacer con IA.

 Errores comunes

Síntoma / mensaje	Causa y cómo arreglar
El modelo cita una CVE que no existe	Alucinación. Verifica siempre en NVD/MITRE antes de usar el dato.
Sugiere una flag de comando que da error	El modelo mezcló versiones o inventó. Contrasta con <code>man / --help</code> .
"No conozco eventos recientes"	Corte de conocimiento. Aporta tú la información actual por contexto.
Respuestas distintas a la misma pregunta	Aleatoriedad. Baja la temperatura y fija el contexto para tareas precisas.
El modelo "olvida" lo dicho antes	Se salió de la ventana de contexto. Reinyecta lo esencial.
Confía ciegamente y ejecuta sin revisar	Falta de HITL. Nunca ejecutes acciones de efecto real sin validar.

 Preguntas frecuentes

 **¿Un LLM puede "hackear solo"?** No de forma fiable ni responsable. Puede sugerir pasos y comandos, pero sin verificación humana y autorización comete errores, alucina y puede causar daño. El humano dirige; el modelo asiste.

? ¿Por qué inventa datos si "sabe" tanto? Porque no consulta una base de hechos: predice texto plausible. Cuando no hay patrón fuerte, rellena con algo que "suena bien". Por eso el grounding y la verificación son imprescindibles.

? ¿Es seguro pegarle logs de un cliente? No sin autorización explícita y sin conocer la política de retención del proveedor. Trátalo como enviar datos a un tercero: aplica minimización, anonimización y consentimiento.

? ¿Sirve para estudiar para certificaciones? Sí, como tutor que explica y genera ejercicios, pero contrasta siempre con el material oficial: puede equivocarse en detalles finos de sintaxis o normativa.

Referencias

- NIST — *Artificial Intelligence Risk Management Framework (AI RMF 1.0)*, NIST AI 100-1 — <https://www.nist.gov/itl/ai-risk-management-framework>
- OWASP — *Top 10 for Large Language Model Applications* — <https://owasp.org/www-project-top-10-for-large-language-model-applications/>
- MITRE ATT&CK — <https://attack.mitre.org/>
- NIST National Vulnerability Database (NVD) — <https://nvd.nist.gov/>
- Anthropic / OpenAI — documentación oficial sobre limitaciones y buenas prácticas de sus modelos.

Siguiente clase

Clase 332 - Agentes de IA y el Model Context Protocol (MCP) para seguridad